# ACC-15 · Acceptable Use & Credential-Sharing Standard

*What this standard adds to the organization's existing acceptable use policy — and how IT applies it when something goes wrong.*

| Field | Value |
|---|---|
| Document ID | ACC-15 |
| Version | 1.0 · Known Good edition, by Kevin Zelman |
| Catalogue domain | B. Account Usage |
| Operating tier | Tier 4 — IT Management owns the policy relationship; every tier applies it. |
| Review cycle | Annually, aligned to the Acceptable Use Policy review. |
| Governing policy | Your organization's acceptable use policy. That policy governs. This standard does not replace it and must not contradict it. If you have no such policy yet, write one first; this standard assumes it exists. |

## 1. Purpose — and what this is not

> **This is not a new acceptable use policy.**
> Most organizations already have one, and where yours exists, it governs.
> The work here is narrower and more useful — confirming that the policy explicitly covers two things IT has repeatedly had to address without written backing, giving IT a consistent way to act when it is breached, and making the policy findable by the people it applies to. Acceptable use policies are often missing from the very page where people look for policies.

If any statement in this standard conflicts with the Acceptable Use Policy, the policy is right and this document is a defect to be reported under GOV-01 §10.

## 2. The three things this standard adds

| Addition | Why it is needed |
|---|---|
| Credential sharing, stated explicitly (§3) | A common case: someone blocked three times is told not to share account access with anyone. That instruction is correct, but it is only spoken. Verbal guidance cannot be cited, is remembered differently by everyone involved, and gives the organization nothing to point at if the matter escalates. |

| Addition | Why it is needed |
|---|---|
| VPN and remote access misuse, stated explicitly (§3) | The same case. A VPN serves staff who need it, and can also be used to hide account sharing. One technology, two populations, and one rule that needs writing down. |
| A consistent ladder for IT's response (§5) | Without one, the response depends on who picks up the ticket. That is unfair to the person on the receiving end and it makes the organization's position inconsistent if a case is ever challenged. |

## 3. Credentials are not transferable

Stated plainly, because the whole point is that it can be quoted.

- Your organization account is yours. You may not give anybody else your password, approve a multifactor prompt on their behalf, or let anybody else use your account — including family, including friends, including colleagues, and including in an emergency.
- You may not use anybody else's account, whether or not they agreed.
- You may not use a VPN, proxy or remote access service to obscure where you are signing in from, or to let somebody else appear to be signing in as you.
- Where a job genuinely needs shared access, the organization provides mechanisms for it — a shared mailbox, a site, a role group — and every one of them records who did what. Ask; the answer is usually yes and takes a day (M365-03, M365-11).

> **Why this one is treated seriously**
>
> Every other control the organization operates assumes an account belongs to one person. Multifactor authentication, audit logs, access reviews, incident investigation and disciplinary processes all rest on that assumption. Sharing a credential does not weaken one control; it removes the foundation under all of them.
>
> It also puts the account holder in a poor position. Everything done with a shared credential is, on the record, done by them.

## 4. What IT will never ask you for

Published so that anybody who is asked knows immediately that something is wrong.

- Your password. Not by email, not on the phone, not in a ticket, not in person. IT does not need it and can do everything it needs without it.
- A multifactor code, or approval of a prompt you did not trigger.
- Your credentials in order to "verify your account". That phrasing is a hallmark of phishing messages. Conversely, IT will ask you to prove who you are before it changes anything on your account, and it will not waive that even when you are in a hurry. That is ACC-06, and it protects you rather than inconveniencing you.

## 5. When it goes wrong — the ladder

Most breaches are not malicious. Somebody helped a friend, or did not realise. The ladder is designed so that the ordinary case is a conversation and the serious case is handled consistently.

| Situation | IT does | Decides | Referred to |
|---|---|---|---|
| First occurrence, no evidence of harm | Restore access, explain the rule, point at the policy. Record it. No further consequence. | Tier 1 or 2 | Nobody |
| Second occurrence within 90 days | Restore. Re-register all MFA methods. Brief the person again, in writing this time. Flag for watch. | Tier 2, Tier 3 informed | Nobody yet |
| Third occurrence within 90 days | Treat as suspected sharing or compromise. Force reset, revoke sessions, re-register everything. Notify the person's department head or manager in writing. | Tier 3 decides; Tier 4 informed | Department head or manager |
| Sharing confirmed by evidence | Suspend access pending referral (ACC-13). Do not restore until the referral concludes. | Tier 4 approves | The person's manager or department head, or HR for employees |
| Credentials sold, or used to obtain something of value | Suspend. Preserve evidence before remediating. Declare an incident. | Tier 4 declares | Manager or department head / HR, and potentially beyond |
| Disciplinary or policy-breach implication | IT supplies the technical facts and nothing else. | The organization's disciplinary process | HR or the relevant department head |

> **Two cautions IT should hold onto**
>
> A repeat count is not evidence. Somebody with one MFA method and an unreliable phone will legitimately appear three times, and treating them as a suspect is both wrong and corrosive to the relationship the service desk depends on. Establish the cause each time (ACC-05 §2).
>
> Distinguishing genuine credential sharing from a person travelling with their own device cannot be done from a sign-in log alone. That distinction is the whole question, and it is worth taking the time to get right before anything reaches a department head.

## 6. Monitoring, and being straight about it

The organization logs authentication, mailbox activity, file access and device state — as any organization running Microsoft 365 does, because those logs are what make security investigation and account recovery possible at all.

- Logs are used for security investigation, incident response, and troubleshooting. They are not read routinely, and there is no general monitoring of what individuals do.
- Access to logs for an investigation is a Tier 4 decision with a recorded reason.

- Where an investigation concerns an employee, HR is involved from the start rather than afterwards.
- The Acceptable Use Policy is the authority for this; §6 exists to state it in language people will actually read. Saying this openly is better practice than leaving it implicit. People assume either that nothing is logged or that everything is watched, and both assumptions cause problems.

## 7. Making it findable

A policy nobody can find is not operating, whatever its status. Three concrete steps, none of which requires new writing:

1. Link the acceptable use policy from the page where the organization publishes its policies. Check the other IT policies are linked there too (GOV-01 §9 step 4).
2. Reference it at the moment it matters: in the ACC-01 §5.3 day-one acknowledgement, in the ACC-09 temporary-worker card, and in the IT signature block on access-related replies.
3. Publish Appendix A as an end-user article on the knowledge base under GOV-05, so that the everyday version is a page rather than a PDF.

## 8. Records

| Record | Held in | Retention |
|---|---|---|
| Acceptable Use acknowledgements | Training / HR record | Duration of relationship + 1 year |
| Ladder actions at each occurrence | Ticket | 3 years |
| Department head or manager notifications | Security record | 3 years |
| Referrals to HR or management | Security record | 7 years |
| Log access decisions, with reason and approver | Tier 4 record | 7 years |

## 9. Related documents

| ID | Title | Relationship |
|---|---|---|
| AUP | Your organization's acceptable use policy | The governing policy. This standard is subordinate to it. |
| Internet Policy | Your organization's internet and network usage policy | Governs the network side of §3; DEV-10 operationalises it. |
| ACC-05 | Account Lockout Triage & Escalation | The §5 ladder is the same ladder, seen from the lockout side. |
| ACC-06 | Identity Verification | §4 — what IT does ask for, and why. |
| ACC-13 | Account Suspension for Misuse or Policy Investigation | Where confirmed sharing goes. |
| ACC-09 | Temporary Worker & Departmental Access Standard | Acknowledgement before access. |

| ID | Title | Relationship |
|---|---|---|
| ACC-01 | Account Lifecycle | Day-one acknowledgement. |
| DEV-07 | Personally-Owned Device Access Standard | Personal devices under the same policy. |
| DEV-10 | Remote Access & VPN Standard | The VPN half of §3. |
| M365-22 | Phishing Reporting & Email Threat Response | §4 is the rule that defeats most of it. |
| GOV-03 | Security Incident Response | Where the bottom of the ladder leads. |
| GOV-05 | Knowledge Base Article Standard | Format for publishing Appendix A. |

## Appendix A — The short version, for publication

Source text for the knowledge base. Format per GOV-05. This is the version people will actually read.

| | |
|---|---|
| Your account is yours | Please do not give anybody your password, approve a login prompt you did not trigger, or let somebody else use your account. Not family, not friends, not colleagues, not in an emergency. |
| Do not use somebody else's | Even if they said it was fine. Everything done with an account is, on the record, done by the person it belongs to. |
| Why it matters more than it sounds | Multifactor authentication, audit logs and account recovery all assume one account, one person. Sharing does not weaken one protection — it removes the ground the others stand on. And it leaves you answering for whatever happens next. |
| If you need shared access, ask | The organization has proper ways to do it — a shared mailbox, a shared site, a role group. They all keep working when somebody is away, and they record who did what. Ask the service desk; it usually takes a day. |
| VPNs and remote access | Do not use a VPN or proxy to disguise where you are signing in from, or to let somebody else appear to be you. Staff who need remote access have a supported way to get it. |
| We will never ask for your password | Not by email, not on the phone, not in a ticket. Anybody who does is not IT — please report it. |
| We will ask you to prove who you are | Before we change anything on your account. It takes about ninety seconds and it is the same check that stops somebody else doing it to your account. |
| If something has gone wrong | Tell us. If you shared a password, or clicked something, or let somebody use your account — telling us early is the single most helpful thing you can do, and it is a much smaller problem on the day than it is a week later. |

Part of the Known Good SOP Catalog by Kevin Zelman, written for small IT shops, contractors and consultants, career-changers and help desk technicians. Adapt the names, tiers and times to your own shop: the times here are cushion, not a promise.